

Dara F. Thomas

Atlanta, GA (Remote) | 619-361-3592 | dara.thomas.grc@gmail.com | linkedin.com/in/daraftthomas | github.com/DaraStaysCurious | darasecures.cloud

GRC Analyst | CompTIA Security+ Certified

Security+ certified professional transitioning into cybersecurity from a background spanning occupational health & safety, UX design, and risk management. My throughline across all three: unsafe behavior is a system design failure, not a human failure. Skilled in risk assessment, root cause analysis, and stakeholder communication — pursuing AWS Cloud Practitioner and CGE-P (Certified GRC Engineer – Practitioner).

CERTIFICATIONS

CompTIA Security+ | AWS Certified Cloud Practitioner (in progress) | Certified GRC Engineer – Practitioner (in progress)

EXPERIENCE

Independent Consultant — UX Strategy & Process Risk Assessment | Remote 01/2020 – Present

- Conducted UX research and design consulting for B2B SaaS clients, applying risk-assessment and process-analysis methods drawn from an OHS background to surface usability and workflow risks other consultants missed
- Led stakeholder assessments and audits to identify process gaps and compliance concerns, presenting findings and recommendations directly to client leadership

Sr. UX Designer, Child Care Aware of America | Arlington, VA (Remote) 11/2023 – 02/2025

- Analyzed business processes and stakeholder requirements to identify risks and process gaps on a large-scale childcare application platform, informing product decisions that reduced downstream compliance and usability risk

Associate UI/UX Designer, Point B | Portland, OR (Remote) 08/2021 – 10/2022

- Led process assessments and workflow analysis on an employee training platform, identifying operational gaps that informed platform redesign priorities

Occupational Health, Safety, & Risk Manager, Various Companies 2000 – 2015

- Companies: Royal Caribbean, Tucker Energy Services, Unilever Caribbean, Unilever Bramalea
 - Led operational risk assessments and compliance audits across manufacturing, maritime, and energy sectors
 - Conducted incident investigations, determined root causes, and developed corrective action plans that reduced recurrence
 - Authored policies, procedures, and training programs to improve compliance and reduce organizational risk
 - Presented findings and recommendations to leadership and regulatory stakeholders
-

TECHNICAL & SECURITY SKILLS

NIST CSF & RMF | ISO 27001 | Risk Assessment | Incident Investigation | Security Documentation | Governance, Risk, & Compliance (GRC) | Threat Analysis | Identity & Access Management (IAM) | Stakeholder Communication | Vulnerability Management | Root Cause Analysis | Qualys | Nessus

PRACTICAL PROJECTS

Risk Assessment Methodology — Developed a crosswalk between the Fine-Kinney risk scoring method and NIST 800-30, proposing Exposure as an explicit variable in GRC risk models; includes three OHS-based case studies applying the framework to real incident scenarios.

ISO 27001 / HIPAA / NIST CSF 2.0 Compliance Program (OccuSafe) — Built a full compliance program for OccuSafe, a case-study healthcare organization, mapping ISO 27001 controls to HIPAA safeguards and NIST CSF 2.0 functions.

PCI DSS v4.0 Compliance Program (PayGuard) — Designed a PCI DSS v4.0 compliance program for PayGuard, a case-study payment processor, covering control implementation and audit readiness.

SOC 2 Type II / HIPAA Audit Readiness (Carestream) — Built a SOC 2 Type II audit readiness assessment integrated with HIPAA requirements for Carestream, a case-study healthcare SaaS company.

GitHub: github.com/DaraStaysCurious | Portfolio: darasecures.cloud

EDUCATION

University of Toronto, Canada — Honors B.A. Sociology and Equity Studies